

Monitoramento e mitigação de riscos em ambientes de TI

A crescente dependência das organizações em relação à tecnologia da informação (TI) tem proporcionado inúmeros benefícios. No entanto, essa intensificação do uso da TI também ampliou a exposição a um conjunto cada vez maior de riscos que, se não forem devidamente gerenciados, podem comprometer tanto a imagem quanto os resultados financeiros das empresas. Incidentes como indisponibilidade de sistemas, ataques de ransomware e falhas de segurança impactam diretamente a continuidade dos negócios e a confiança de clientes, parceiros e investidores. Nesse cenário, o monitoramento constante e a adoção de estratégias eficazes de mitigação se tornaram elementos decisivos na gestão de riscos em ambientes de TI.

Neste capítulo, abordaremos, em um primeiro momento, os riscos considerados mais significativos para as organizações, destacando as ameaças de indisponibilidade e ataques cibernéticos. Em seguida, serão discutidas as estratégias de mitigação contínua, que incluem a correção de vulnerabilidades em tempo real, a automação de respostas a incidentes e a atualização frequente de sistemas e aplicações. Essas práticas, quando aplicadas de forma integrada, permitem reduzir a probabilidade de falhas e reforçar a resiliência organizacional diante de eventos inesperados.

Por fim, serão explorados os indicadores que auxiliam na avaliação da efetividade das ações de monitoramento e mitigação. Dentre eles, destacam-se as métricas de desempenho e os indicadores-chave de risco (KRIs – key risk indicators), que fornecem uma visão clara sobre o nível de exposição da empresa e o sucesso das medidas implementadas. Dessa forma, este capítulo busca oferecer um panorama prático e teórico sobre como alinhar ferramentas, processos e métricas, capacitando os profissionais a implementarem uma gestão de riscos mais robusta e estratégica em ambientes de TI.

1 Riscos que podem afetar a imagem e o financeiro da empresa

Os ambientes de TI estão cada vez mais estabelecidos como base das operações organizacionais, sustentando processos internos e interações entre os mais diversos stakeholders (partes interessadas) das organizações. Quando ocorrem falhas ou ataques, normalmente as consequências ultrapassam o aspecto técnico, atingindo diretamente a reputação e a saúde financeira da organização. Interrupções prolongadas de serviços, por exemplo, podem comprometer contratos, gerar multas por descumprimento de acordo de nível de serviço (SLA – service level agreement) e afetar a confiança dos clientes, que buscam alternativas mais seguras no mercado.



IMPORTANTE

Risco: refere-se à probabilidade de que um evento adverso ocorra, ocasionando impactos negativos em projetos, processos ou serviços, com potenciais efeitos negativos sobre objetivos, recursos ou resultados (Konopczyk, 2022).

SLA (service level agreement): é um acordo formal entre fornecedor e cliente que estabelece os níveis de serviço esperados, incluindo disponibilidade, desempenho e tempo de resposta, servindo para monitorar e garantir a qualidade do serviço (Freitas, 2013).

Nesse contexto, a gestão de riscos em TI vai se consolidando como um requisito operacional e ao mesmo tempo um fator estratégico de proteção ao negócio. Ela ajuda a mapear incidentes (por exemplo, de indisponibilidade) e ataques (como ransomware) que podem impactar os negócios.

Outro fator relevante a ser mencionado em relação à gestão de riscos é que, no mapeamento de muitas ameaças, percebe-se que a sua origem, além de ser externa, pode ser interna. Entre essas ameaças de cunho interno estão: reação de funcionários insatisfeitos; falhas operacionais; e negligência em práticas de segurança. Como exemplo, podemos citar o procedimento descuidado de um colaborador que compartilha credenciais de acesso ou deixa dispositivos desprotegidos, abrindo brechas para a entrada de atacantes. Outro exemplo é a falta de atualização em sistemas e aplicações, fator que contribui para a exploração de vulnerabilidades já conhecidas, que tornam a organização um alvo ainda mais “atraente” para hackers e pessoas mal-intencionadas (Pegetti, 2023).

É importante acrescentar também que a repercussão financeira de um incidente de segurança é outra parte do problema. Muitas empresas enfrentam crises de imagem após a exposição pública de falhas, com perda de credibilidade perante clientes, acionistas e sociedade em geral. Em setores regulados (como o financeiro e o da saúde, por exemplo) os

impactos podem ser ainda maiores, envolvendo multas e sanções legais devido ao descumprimento de normas de proteção de dados, como a LGPD no Brasil.

1.1 Riscos de indisponibilidade e ransomware

A indisponibilidade de sistemas em ambientes de TI é uma das falhas mais críticas que uma organização pode enfrentar. Mesmo pequenas interrupções podem causar prejuízos significativos, já que muitas empresas dependem de sistemas sempre ativos para atender clientes, processar transações e manter operações básicas (Machado, 2014; Pegetti, 2023; Konopczyk, 2022).

Para melhor compreender a gravidade desse problema, pense em uma empresa de aviação comercial, que tem a maioria maciça de suas vendas feita no ambiente virtual. Perceba que a quebra de continuidade nesse tipo de serviço compromete a confiança dos usuários e abre espaço para que concorrentes (outras empresas de aviação comercial) se beneficiem da situação.

Entre os tipos de ameaças que circulam no contexto atual, o ransomware está entre as mais agressivas. Esse tipo de ataque consiste em criptografar dados da organização e exigir pagamento para a liberação do acesso. Além do impacto operacional imediato, há o risco de que informações sensíveis sejam expostas ou vendidas, mesmo após o pagamento do resgate. Empresas de todos os portes são alvos, mas aquelas com baixa maturidade em segurança ou com sistemas desatualizados são particularmente mais vulneráveis (Pegetti, 2023).

Recorrendo a um exemplo no Brasil, podemos citar o caso do Banco Neon, ocorrido em fevereiro de 2025, que foi alvo de um ataque cibernético efetuado por um hacker identificado como “Pegasus”. Esse invasor divulgou dados sensíveis de aproximadamente 30 milhões de clientes, admitindo ter explorado uma falha de segurança nos sistemas do banco,

e pediu, em seguida, um resgate de 5 bitcoins (cerca de R\$ 2,8 milhões) para devolver as informações. Os dados vazados incluíam informações como CPF, nome completo, e-mail, número da conta, saldo, histórico de transações via Pix, entre outros. O Banco Neon confirmou o incidente, mas afirmou que as informações vazadas não permitiam acesso às contas bancárias nem à realização de transações financeiras (Hacker [...], 2025).

Os dois riscos (indisponibilidade e ransomware), facilmente identificáveis nas situações de ciberataques, têm em comum a capacidade de afetar simultaneamente a organização nas perspectivas financeira e de imagem. Os casos conhecidos (como o do Banco Neon) reforçam que os impactos não estão limitados ao ambiente digital, mas atingem diretamente pessoas, processos e a própria continuidade dos negócios.

Por esse motivo, para a maior parte das empresas (principalmente aquelas com operações no ambiente digital) o enfrentamento dos riscos de indisponibilidade e ransomware deve estar no centro das políticas de segurança das organizações. Isso envolve o uso de ferramentas de monitoramento em tempo real, práticas de backup confiável, conscientização dos usuários, fortalecimento da governança de TI, além da adesão a normas internacionais de segurança. Com uma abordagem proativa, é possível reduzir consideravelmente os impactos dessas ameaças e proteger tanto os ativos digitais quanto a reputação da empresa.

1.1.1 Monitoramento em tempo real

O monitoramento em tempo real é uma importante prática que ajuda a detectar e reagir rapidamente a eventos que podem causar indisponibilidade ou comprometer dados. Ele é construído por meio de informações oriundas de diversos pontos da infraestrutura (como, por exemplo, logs de servidores, tráfego de rede, eventos de endpoints e alertas de firewalls e IDS/IPS). Essas informações são apresentadas em painéis que permitem à equipe operacional identificar anomalias quando elas surgem (Konopczyk, 2022).

Uma arquitetura típica de monitoramento em tempo real combina diversos elementos que podem ser vistos no quadro 1. Para cada elemento mencionado é possível ver o benefício principal obtido por ele.

Quadro 1 – Elementos da arquitetura típica de monitoramento em tempo real

ELEMENTO	DESCRIÇÃO	BENEFÍCIO PRINCIPAL
Coletores de logs	Reúnem registros de atividades de diferentes fontes (servidores, aplicações, dispositivos de rede).	Centralização e visibilidade unificada dos eventos.
Siem (security information and event management)	Analisa os logs coletados, correlacionando eventos e identificando padrões suspeitos.	Detecção precoce de ameaças complexas.
Nids (network intrusion detection system)	Monitoram o tráfego em tempo real para identificar tentativas de intrusão ou comportamentos anômalos.	Visibilidade e proteção no tráfego de rede.
EDR – (endpoint detection and response)	Instalados em computadores e servidores, registram atividades locais e identificam ataques direcionados.	Detecção detalhada em dispositivos finais.
Regras para alertas	Critérios pré-definidos que disparam notificações em situações críticas.	Resposta mais rápida a incidentes relevantes.
Playbooks automatizados	Procedimentos padronizados e automatizados que orientam a reação a incidentes.	Redução do tempo de resposta e mitigação de falhas.

Fonte: adaptado de Vieira (2025) e Valente (2022).

Além da série de benefícios obtidos a partir desses elementos que o constituem, podemos mencionar, de forma geral, que o monitoramento em tempo real ajuda na: detecção precoce de incidentes; priorização de respostas conforme criticidade; e suporte à tomada de decisão com evidências auditáveis.

É importante também mencionar a existência de limites práticos que se apresentam nesse contexto. Dentre esses limites, destacam-se: volumes elevados de dados, que podem gerar muitos falsos positivos,

exigindo ajustes finos nas regras; criptografia ponta a ponta, que pode impedir inspeção profunda do tráfego; e dependência de pessoas qualificadas para interpretar alertas e executar ações de forma eficaz (Machado, 2014; Agra; Barboza, 2018).

1.2 Estratégias de mitigação contínua

A mitigação contínua de riscos em ambientes de TI é uma das importantes atividades de gestão de riscos. Ela visa assegurar a resiliência e a disponibilidade dos serviços de TI e funciona como um mecanismo permanente de prevenção, correção e resposta frente a incidentes de segurança. As estratégias de mitigação contínua de riscos reduzem a probabilidade de falhas e ataques bem-sucedidos, principalmente se as superfícies de ataque são maiores e mais críticas (Barreto *et al*, 2018).

O conceito de mitigação contínua está relacionado à capacidade das organizações de manter uma postura de vigilância permanente. Isso inclui corrigir vulnerabilidades (assim que são detectadas) além de automatizar respostas a incidentes, garantindo que os sistemas estejam atualizados. De acordo com Machado (2014), essas práticas de mitigação contínua são preventivas e devem ser associadas a outras práticas reativas, de maneira a preservar a integridade, a confidencialidade e a disponibilidade da informação.

Dessa forma, as estratégias de mitigação contínua formam um ciclo dinâmico: inicialmente identificamos falhas, depois aplicamos correções, posteriormente automatizamos respostas e, por fim, mantemos a infraestrutura sempre ajustada na perspectiva de ocorrência de novas ameaças. Essa dinâmica possibilita que os riscos sejam reduzidos antes que evoluam para crises com impacto operacional e financeiro significativo.

1.2.1 Correção de vulnerabilidades em tempo real

Dentro do contexto da mitigação contínua, encontramos a correção de vulnerabilidades. Essa ação relaciona-se à capacidade de identificar brechas de segurança no exato momento em que são descobertas e aplicar soluções imediatas. Lima (2018) ressalta que ferramentas de monitoramento avançadas permitem a detecção automatizada de falhas, possibilitando que equipes de TI priorizem ações corretivas antes que um invasor explore a fragilidade.

Um exemplo prático pode ser observado em sistemas de bancos digitais. Caso seja identificada uma vulnerabilidade em uma API de pagamento, a correção precisa ocorrer de forma imediata para evitar fraudes em larga escala. Esse tipo de resposta rápida garante que a indisponibilidade e os impactos financeiros sejam minimizados.

Apesar dos benefícios, essa prática exige recursos tecnológicos e humanos altamente especializados. Muitas organizações ainda encontram dificuldades em adotar tais mecanismos por dependerem de fornecedores externos para atualizações. Assim, a correção em tempo real deve ser acompanhada de uma estratégia clara de priorização e testes de segurança recorrentes (Pegetti, 2023).

1.2.2 Automação de respostas a incidentes

Para reduzir de forma decisiva a dependência existente da ação humana no contexto da gestão de riscos, recorre-se à automação de resposta como uma reação rápida diante de incidentes.

Ferramentas de automação permitem, por exemplo, que um sistema bloqueie automaticamente um usuário que tenha realizado diversas tentativas de login malsucedidas, mitigando ataques de força bruta. Outra possibilidade é o isolamento automático de máquinas suspeitas dentro de uma rede corporativa, preservando os demais ativos críticos (Agra; Barboza, 2018).

Contudo, embora a automação traga ganhos de velocidade e eficiência, é preciso reconhecer que, se mal configurada, pode gerar falsos positivos e comprometer processos legítimos. Por isso, a integração entre automação e análise humana é indispensável, pois garante que as medidas sejam eficazes e proporcionais ao risco identificado.

1.2.3 Atualização e patching de sistemas e aplicações

A atualização e aplicação de patches é talvez uma das estratégias mais tradicionais e está entre as mais relevantes na mitigação de riscos. Muitas vulnerabilidades exploradas por atacantes decorrem da falta de atualização de softwares, sistemas operacionais e aplicações. Essa negligência em aplicar patches abre caminho para ataques amplamente conhecidos e já documentados.



IMPORTANTE

Um patch é uma correção disponibilizada por desenvolvedores de software para resolver falhas de segurança e erros de funcionamento ou melhorar a performance de um sistema ou aplicação. Já o termo patching refere-se ao processo de aplicar esses pacotes de correção de forma sistemática e planejada. Esse processo é essencial para manter a integridade e a confiabilidade de ambientes de TI, pois reduz a exposição a vulnerabilidades conhecidas e garante que o software esteja alinhado às versões mais seguras e estáveis.

No Brasil, um caso notório demonstrou as graves consequências de uma atualização mal planejada. Em julho de 2024, uma correção da empresa de segurança CrowdStrike causou uma falha que afetou sistemas bancários em várias instituições (Bradesco, Neon, Next e Pan), além de comprometer sistemas de companhias aéreas, gerando atrasos em voos e instabilidades financeiras. A Microsoft teve que orientar a

reinicialização de sistemas e aplicar medidas emergenciais para conter os danos gerados pela falha (Agência Brasil, 2024).

O desafio, contudo, está em manter um equilíbrio entre a necessidade de aplicar correções rapidamente e a continuidade dos serviços. Atualizações não testadas podem gerar incompatibilidades ou até falhas operacionais. Nesse sentido, a prática recomendada é estabelecer uma rotina de gerenciamento de patches, com testes em ambientes controlados e cronogramas de implantação que considerem a criticidade de cada sistema.

1.3 Indicadores de desempenho e efetividade

Segundo Peter Drucker (1974), “se não podemos medir, também não podemos gerenciar”. Essa é a lógica que sustenta a importância do uso de indicadores na administração de forma geral, mas que pode ser facilmente aplicada à gestão de riscos em TI. Drucker (1974) destacou que a mensuração é uma condição indispensável para a gestão eficaz, pois apenas aquilo que pode ser avaliado em termos de resultados pode ser devidamente controlado. Nesse sentido, a definição e o acompanhamento de indicadores são passos indispensáveis para compreender se os controles técnicos e as estratégias de segurança realmente estão alcançando os efeitos esperados.

No campo da gestão de riscos em ambientes de TI, os indicadores de desempenho e efetividade cumprem esse papel ao medir a capacidade de prevenção, detecção e resposta a incidentes. Eles permitem transformar dados brutos e operacionais em métricas gerenciais que orientam a tomada de decisão de forma clara e objetiva. A partir dessa perspectiva, não apenas monitoramos eventos técnicos, mas verificamos se os mecanismos de segurança estão alinhados aos resultados almejados pela organização.

Ao mesmo tempo, esses indicadores contribuem para criar uma visão sistêmica da segurança, permitindo que os gestores comparem tendências, identifiquem fragilidades e ajustem rapidamente as estratégias. Dessa forma, a mensuração deixa de ser uma atividade meramente operacional e passa a ser estratégica, conectando a proteção dos ativos digitais às metas de negócio e fortalecendo a resiliência organizacional.

1.3.1 Métricas de desempenho em monitoramento de riscos

As métricas de desempenho permitem avaliar se os controles técnicos e as práticas de segurança estão cumprindo o papel esperado. Diferente de análises qualitativas, que oferecem uma visão mais interpretativa, as métricas fornecem números objetivos que ajudam a acompanhar tendências e comparar resultados ao longo do tempo.

Essas métricas funcionam como termômetros que apontam se os controles estão atendendo às expectativas. Por exemplo, se uma empresa consegue reduzir uma métrica de desempenho conhecida como MTTR de 12 horas para duas horas, isso significa que seus processos de resposta se tornaram mais ágeis e eficazes.

Alguns exemplos de métricas comumente utilizadas em ambientes de TI são:

- **MTTD (mean time to detect – tempo médio de detecção):** avalia o intervalo entre o início de um incidente e a sua detecção pela equipe de segurança ou pelas ferramentas de monitoramento. Um MTTD elevado mostra que os controles estão lentos em identificar anomalias, o que aumenta a janela de exposição do ambiente. Por exemplo, se um malware permanece ativo durante dias sem ser percebido, a probabilidade de causar danos financeiros e comprometer dados sigilosos cresce exponencialmente. Organizações com baixo MTTD tendem a ter maior capacidade de resposta e confiança junto a clientes e reguladores.

- **MTTR (mean time to respond – tempo médio de resposta):** mede o tempo entre a detecção de um incidente e a adoção de medidas que neutralizam a ameaça ou recuperam os serviços afetados. Quanto menor o MTTR, menor será o impacto operacional e financeiro. Considere, por exemplo, um comércio eletrônico que sofre um ataque de negação de serviço (DDoS). Se a resposta demorar dez horas, os prejuízos podem incluir perda de vendas e danos à reputação; se a reação ocorre em apenas uma hora, o efeito negativo será consideravelmente menor.
- **Taxa de indisponibilidade:** expressa em percentual, essa métrica mostra quanto tempo os sistemas críticos ficaram inoperantes em relação ao período total. Ela está diretamente relacionada a contratos de SLA (service level agreement) e à percepção de confiabilidade pelos usuários. Por exemplo, uma taxa de indisponibilidade de 0,5% em um banco digital pode parecer pequena, mas pode significar horas de indisponibilidade em que milhares de transações deixam de ser realizadas. Esse indicador, quando monitorado em conjunto com causas-raiz, orienta investimentos em redundância e resiliência da infraestrutura.
- **Volume de falsos positivos:** representa a quantidade de alertas emitidos pelas ferramentas de segurança que não correspondem a incidentes reais. Um número elevado sobrecarrega as equipes de resposta, gera fadiga operacional e pode fazer com que alertas verdadeiros passem despercebidos. Por exemplo, se um IDS gera centenas de falsos positivos por dia, a equipe pode gastar tempo valioso investigando eventos irrelevantes. Essa métrica serve de guia para ajustar as regras de detecção, calibrar sensores e até avaliar a troca de tecnologia.
- **Conformidade em atualizações:** mede o percentual de servidores, sistemas e aplicações que estão em dia com patches de segurança. Um índice alto de conformidade significa que a organização está

reduzindo a superfície de ataque relacionada a vulnerabilidades conhecidas. Já um índice baixo indica risco elevado de exploração. Como exemplo, falhas amplamente divulgadas, como a do Log4j em 2021, mostraram como empresas sem processos ágeis de atualização ficaram expostas a ataques em larga escala. Essa métrica deve ser acompanhada de perto, pois está diretamente ligada ao nível de exposição da infraestrutura frente a ameaças conhecidas.

Contudo, as métricas de desempenho não devem ser vistas isoladamente. Os indicadores quantitativos precisam ser complementados por análises qualitativas, como auditorias de conformidade e testes de resiliência. Só assim é possível ter uma visão completa sobre a efetividade das medidas de segurança.

1.3.2 Key risk indicators (KRIs) aplicados à gestão de TI

Os key risk indicators (KRIs) são indicadores voltados para a antecipação de riscos, funcionando como sinais de alerta que permitem agir antes que a ameaça cause impactos relevantes (Barreto *et al.*, 2018). Eles diferem das métricas de desempenho porque não medem a eficiência do processo em si, mas apontam o nível de exposição da organização a determinados riscos.

Alguns exemplos de KRIs em ambientes de TI são:

- **Aumento de tentativas de login malsucedidas:** esse indicador aponta, em muitos casos, a ocorrência de ataques de força bruta ou tentativas automatizadas de acesso. Quando há crescimento repentino desse número, a equipe de segurança precisa verificar se há campanhas ativas contra sistemas críticos, como portais corporativos ou serviços de e-mail. Além disso, pode sinalizar falhas nos mecanismos de autenticação ou necessidade de implantar camadas adicionais, como autenticação multifator.

- **Crescimento anormal do tráfego de rede:** uma elevação abrupta no volume de dados circulando pode representar ataques de negação de serviço distribuído (DDoS), que buscam indisponibilizar serviços essenciais. Esse indicador também pode apontar movimentações laterais de malware já instalado na rede. Monitorar esse crescimento em tempo real permite que medidas preventivas, como redirecionamento de tráfego ou ativação de soluções anti-DDoS, sejam aplicadas rapidamente.
- **Percentual de sistemas críticos sem atualização:** manter um alto índice de sistemas desatualizados representa risco elevado de exploração por criminosos digitais. Esse indicador ajuda a mapear a exposição da infraestrutura e priorizar ações de patching. Organizações que monitoram esse indicador conseguem agir rapidamente, reduzindo a probabilidade de exploração.
- **Número de acessos privilegiados não revisados:** acessos administrativos ou de alto nível devem passar por auditorias regulares. Quando há aumento desse número sem revisão, o risco de uso indevido, seja por funcionários internos ou atacantes que tenham comprometido credenciais, cresce de forma significativa. Esse indicador orienta políticas de governança de identidades e reforça a importância do princípio do menor privilégio.
- **Volume de alertas não tratados dentro do SLA:** quando incidentes ou notificações permanecem sem resposta no prazo estipulado, a organização perde capacidade de reação. Esse KRI aponta falhas de priorização ou sobrecarga da equipe de segurança. Se, por exemplo, 40% dos alertas permanecem abertos além do prazo, a probabilidade de um ataque avançar sem mitigação aumenta consideravelmente. Esse indicador também serve como base para avaliar a necessidade de ampliar a equipe de resposta ou investir em automação de processos de segurança.

Os KRIs são eficazes quando associados a limites de tolerância previamente definidos pela organização. Ao ultrapassar esses limites, os indicadores acionam respostas automáticas ou alertas para os gestores. Essa prática contribui para reduzir o tempo entre a identificação e a mitigação de riscos, fortalecendo a postura preventiva da empresa.

Considerações finais

O monitoramento e a mitigação de riscos em ambientes de TI representam um desafio constante para as organizações modernas, dada a complexidade dos sistemas e a crescente sofisticação das ameaças. A adoção de processos de monitoramento contínuo, apoiados em métricas de desempenho e indicadores de risco, permite reagir a incidentes e antecipar potenciais vulnerabilidades que poderiam comprometer a disponibilidade e a confiabilidade dos serviços.

As estratégias de mitigação analisadas (correção em tempo real, automação de respostas e patching de sistemas) evidenciam que a sustentabilidade organizacional depende da agilidade na tomada de decisões e da integração entre pessoas, processos e tecnologias. Nesse sentido, o uso de ferramentas de monitoramento inteligente e de políticas bem-definidas reduz os impactos financeiros e protege a imagem institucional frente a incidentes graves, como indisponibilidades prolongadas ou ataques de ransomware.

Outro aspecto primordial é a utilização de métricas de desempenho e de KRIs para transformar dados operacionais em informações estratégicas. Esse alinhamento entre monitoramento técnico e gestão corporativa reforça a governança e garante maior previsibilidade para os negócios. Assim, a segurança deixa de ser apenas uma barreira defensiva e passa a ser um diferencial competitivo, fortalecendo a confiança de clientes e parceiros.

Em resumo, o monitoramento e a mitigação contínua devem ser entendidos como um ciclo permanente, em que cada aprendizado contribui para a maturidade organizacional. Investir em mecanismos de prevenção, mensuração e resposta ajuda a reduzir as vulnerabilidades e posicionar a empresa em um patamar de maior de proteção diante das incertezas do ambiente digital.

Referências

AGÊNCIA BRASIL. Entenda falha no sistema da CrowdStrike que causou apagão cibernético. **UOL**, 19 jul. 2024. Disponível em: <https://noticias.uol.com.br/ultimas-noticias/agencia-brasil/2024/07/19/entenda-falha-no-sistema-da-crowdstrike-que-causou-apagao-cibernetico.htm>. Acesso em: 9 set. 2025.

AGRA, A. D.; BARBOZA, F. F. M. **Segurança de sistemas da informação**. Porto Alegre: Sagah, 2018.

BARRETO, J. S.; ZANIN, A.; MORAIS, I. S.; VETTORAZZO, A. S. **Fundamentos de segurança da informação**. Porto Alegre: Sagah, 2018.

DRUCKER, P. F. **Management**: tasks, responsibilities, practices. Nova York: Harper & Row, 1974.

FREITAS, M. A. S. **Fundamentos do gerenciamento de serviços de TI**. 2. ed. Rio de Janeiro: Brasport, 2013.

HACKER divulga dados bancários de 30 milhões de clientes do Neon. **Poder360**, 12 fev. 2025. Disponível em: <https://www.poder360.com.br/poder-tech/hacker-divulga-dados-bancarios-de-30-milhoes-de-clientes-do-neon/>. Acesso em: 8 set. 2025.

LIMA, A. **Gestão da segurança e infraestrutura da tecnologia da informação**. São Paulo: Editora Senac São Paulo, 2018.

MACHADO, F. N. R. **Segurança da informação**: princípios e controle de ameaças. São Paulo: Érica, 2014.

PEGETTI, A. **Gestão da segurança da informação**. São Paulo: Editora Senac São Paulo, 2023.

KONOPCZYK, M. G. **Riscos, auditoria e resposta a incidentes**. São Paulo: Editora Senac São Paulo, 2022.

VALENTE, R. P. **Motor de inferência aplicado à detecção de incidentes de segurança no ciberespaço de uma organização**. 2022. 138 f. Dissertação (Mestrado em Informática e Gestão) – ISCTE – Instituto Universitário de Lisboa, Lisboa, 2022.

VIEIRA, A. A. de S. **Metodologia integrativa para a detecção e prevenção de ameaças utilizando inteligência de ameaça cibernética e Sien**. 2025. 60 f. Dissertação (Mestrado Profissional em Engenharia Elétrica) – Departamento de Engenharia Elétrica, Faculdade de Tecnologia, Universidade de Brasília, Brasília, DF, 2025.

